

We can run a `nmap` command on the subnet to find hosts that are up, with the option `-sP`. `nmap` tells us also the virtualization environment, determined via the mac address.

Remember that with `--reason` we can get more information on the scan.

Part missing, he was going a bit too fast.

Metasploit allows to create a stateless payload, which means that we can deliver our payload either in stages (with a small initial payload connecting to the attacked, then downloading the rest on the machine), and the stateless one, with a single state execution.

We've been talking about payloads, using meterpreter payloads. They can do different things, like generating shells.

Metasploits offer a tool `msfvenom`, through which we can create payloads. It can encode these payloads as well, helping to avoid filters.

Remote Access

We will see how to interact with other systems in an unconventional way, having limited interactivity, lacking comforts we're used to.

A remote exploit is aimed to execute code on the target machine, reading or writing files on the remote system. Often what happens is that we upload stuff to the target, then executing it.

Imagine we're hacking a web server. What we do is trying to find a vulnerability, uploading a file (like a php framework). We could upload a webshell, which is a page written in a language interpreted by the server, and then we connect to the webshell, allowing us to interact with the target system. Commands issued through the webshell will be executed in the context of web server, so we will have the same privileges (not always root though).

Another case is when we have some sort of remote code execution, and we inject a reverse shell. We inject a meterpreter code, and this code connects back to our machine. Through this connection, we can execute commands on the underlaying operating system. Reverse shells are important as sometimes we only have access to a limited sets of ports.

Another use of shells is for lateral movement. This takes place when we already have a foothold in the machine, and we need to escalate privileges. We talk about lateral movement as it's difficult to get root directly from one non privileged user. We may want to leverage a shell to do so, tricking the system. A typical case is given by setting uid on a binary, injecting code through a buffer overflow attack, allowing the code to be executed with the privileges of the owner of a file.

Let's take a look at a taxonomy of a shell. We differentiate between web shells and other types. We can have TCP and UDP shells, this applies to both types of shells, but it's not typical that web shells use UDP. A web shell could even be a reverse shell.

We can further categorize shells as Bind or Reverse Shells. With a Bind shell, we connect to the shell, setting up a port and connecting to it. The difference is that in the first case we need to be able to reach that port from the attacker machine, in the second case the target machine connects back to us.

We also have encrypted and non encrypted machines.

Take a look at the photo on slides to determine connections.

What shell do we need to use? It depends on the situation.

Let's dive deeper in what a bind shell is. In a simple example we create a socket, bind and listen on it. Then, take the stdin, out and err, duping it on the network connection. Then, use the `execve()` command.

In practice, we don't need to write our own shell. We'll use tools like `netcat`, `socat`, `living of the land` (using some tools to create shells, like `bash`), `metasploit` with `meterpreter` and `msfvenom`.

Let's start by taking a look at `netcat`.

Through `netcat` we'll be able to get a network shell, or a tunnel. It can also be used for port scanning.

Let's start by TCP bind shell. We have to perform on the victim box `nc -e bash -lp 4444` and on the attack box `nc ip 4444`.

For the reverse shell, we first setup the attack box, then the victim box.

It's not going to work on linux, as `-e` flag was removed, as it was highly insecure.

We can work around it in different ways though. We use the `fifo`, a named pipe.

It creates a bidirectional buffered virtual file. We can use the `mkfifo` command.

We redirect input coming from the `fifo` into `netcat`.

More info on the capture files and slides.

We can also create a UDP Bind shell. We have specific commands to run both on the victim box, and the attack box. We can do this with a reverse shell as well.

Another tool is `socat`. It can be used to listen and establish connections for various systems using proxy.

We can do the bind shell and reverse shell with socat as well.

Socat is better also at encryption level.

There is a site <http://explainshell.com> that we can use to explain commands.

We have <http://revshells.com> as well as a site.

Let's dive deeper now in metasploit shells. As we've seen, there are two types of payloads with meterpreter: staged and stateless.

The framework includes a lot of payloads, like a VNC server, direct executions, etc.